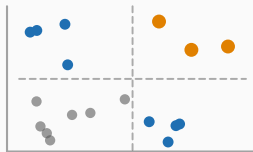


Risque opérationnel et résilience

Chapitre 5 : L'atténuation des risques



Avant de commencer

Le choix de la réponse au risque

Les contrôles internes

La qualité des processus et l'erreur humaine

La gestion des nouveaux projets et des acquisitions

Continuité d'activité et gestion de crise

Le transfert du risque

La gestion du risque réputationnel

Synthèse

Avant de commencer

Pourquoi ce chapitre ?

Après l'identification et l'évaluation, ce chapitre couvre la troisième étape du cycle de gestion des risques : l'atténuation. Il présente le choix de la réponse au risque, les contrôles internes et leur test, la maîtrise du risque dans les nouveaux projets, les mesures de continuité et de gestion de crise, le transfert du risque, et la gestion du risque réputationnel.

Le choix de la réponse au risque

Risques externes et risques internes

Les risques opérationnels **externes** — liés à l'environnement d'affaires ou à des événements extérieurs — ne peuvent être réduits qu'en diminuant l'exposition ou en optimisant la réponse d'atténuation. Les risques opérationnels **internes** — liés aux personnes, processus et systèmes — sont bien plus maîtrisables, principalement par les contrôles internes, dans une logique active de compromis rendement-coût.

Les quatre réponses au risque (les « 4 T »)

Tolérer, traiter, transférer, terminer

La norme ISO 31000 distingue quatre réponses possibles au risque. **Tolérer** consiste à accepter le risque tel quel, pour les risques inhérents faibles ou déjà bien maîtrisés. **Traiter** regroupe toutes les mesures d'atténuation, principalement les contrôles internes. **Transférer** déplace la conséquence du risque vers un tiers, typiquement par l'assurance ou l'externalisation — sans jamais transférer la responsabilité vis-à-vis du client. **Terminer** supprime toute l'exposition en cessant l'activité concernée — une réponse extrême, réservée aux cas où les inconvénients dépassent clairement les bénéfices.

Les contrôles internes

Préventifs, détectifs, correctifs, directifs

Les contrôles **préventifs** réduisent la probabilité d'un incident en agissant sur ses causes — la séparation des tâches en est l'exemple le plus connu, appliquée par exemple entre l'initiation, la validation et le règlement d'une transaction. Les contrôles **détectifs** signalent la survenue d'un incident et accélèrent sa résolution — rapprochements de comptes, systèmes de détection d'activité réseau suspecte. Les contrôles **correctifs** réduisent l'impact une fois l'incident survenu — sauvegardes de données, plans de continuité. Les contrôles **directifs** — politiques, procédures, formations — structurent la conduite des opérations en amont de tout événement.

Un contrôle clé suffit à lui seul

Un **contrôle clé** (ou primaire) est suffisant à lui seul pour empêcher la matérialisation du risque ; un contrôle secondaire ne fait que renforcer un contrôle clé sans pouvoir, seul, neutraliser le risque. L'automatisation d'un contrôle en accroît généralement la fiabilité — mais transforme un risque de défaillance humaine en un risque de défaillance technologique ou de modèle, transformant un risque de probabilité élevée et d'impact faible en un risque de probabilité faible mais d'impact potentiellement systémique.

Étude de cas : la perte de trading de Knight Capital

En août 2012, Knight Capital, alors l'un des plus grands teneurs de marché au monde, a perdu près de 460 millions USD en 45 minutes à cause d'un code défectueux déployé dans son système de routage d'ordres, générant des millions d'ordres erronés sur 154 titres. La cause : réutilisation de code obsolète, contrôle de versions inadéquat, tests insuffisants, absence de hiérarchisation des alertes, et absence de procédure d'urgence pour activer le coupe-circuit qui aurait arrêté toutes les transactions du système.

Quatre niveaux de rigueur croissante

L'auto-certification (ou enquête déclarative) offre l'assurance la plus faible, réservée aux contrôles secondaires à faible risque. L'examen documentaire s'appuie sur des preuves écrites du processus et de ses résultats. L'observation en temps réel du fonctionnement du contrôle est plus rigoureuse mais limitée dans le temps. La reperformance — reproduire le contrôle sur un échantillon et comparer les résultats, par exemple via le « client mystère » ou l'insertion de transactions fictives — constitue la forme de test la plus exigeante.

Plus de contrôles ne signifie pas moins de risque

Un contrôle mal conçu — « optimiste » (exigeant une vigilance surhumaine du contrôleur) ou « collectif » (diluant la responsabilité entre plusieurs personnes, comme un contrôle à quatre yeux mal implémenté) — peut donner un faux sentiment de sécurité. Répondre à une défaillance de contrôle en ajoutant simplement « plus de la même chose » dilue encore davantage la responsabilité au lieu de la renforcer.

La qualité des processus et l'erreur humaine

Glissement, erreur, violation

James Reason distingue trois types d'actions humaines à l'origine d'incidents opérationnels. Le **glissement** (« slip ») est une erreur involontaire due à l'inattention ou à la fatigue — la classique « faute de frappe » inversant un chiffre dans une transaction. L'**erreur fondée sur des règles ou des connaissances** (« mistake ») résulte d'un choix volontaire mais inadéquat — par exemple une vente inappropriée motivée par des incitations commerciales agressives. La **violation** est un manquement volontaire : l'auteur connaît la règle mais choisit délibérément de s'en écarter.

Des réponses différenciées selon le type d'erreur

Les glissements se traitent par un meilleur environnement de travail et une charge de travail adaptée. Les erreurs fondées sur les connaissances appellent des contrôles directifs — formation, procédures documentées, fichiers d'aide. Les violations se traitent par des contrôles de supervision (hiérarchiques ou automatisés) et par le renforcement d'une culture de conformité qui récompense le respect des règles.

Six Sigma, Lean, DMAIC et PDSA

Le Six Sigma et sa variante Lean Six Sigma visent à réduire la variabilité et le gaspillage des processus via le cycle DMAIC (définir, mesurer, analyser, améliorer, contrôler). Le cycle PDSA (planifier, exécuter, étudier, agir), ou « roue de Deming », structure de façon similaire l'amélioration continue de la qualité, largement utilisé dans la santé et de plus en plus dans les services financiers.

La gestion des nouveaux projets et des acquisitions

NPAP et NIRAP

Le processus d'approbation des nouveaux produits (NPAP) et sa généralisation aux nouvelles initiatives (NIRAP) exigent qu'un dossier d'affaires couvre au minimum cinq volets : objectif, alternatives envisagées, bénéfices attendus, aspects commerciaux, et risques et leur atténuation. L'intensité de l'implication de la fonction risque dépend de la criticité du projet.

Les acquisitions héritent de risques opérationnels invisibles

Contrairement au risque de crédit d'un portefeuille acquis, généralement bien documenté, le risque opérationnel d'une entité acquise est un « squelette dans le placard » qui peut ne se révéler que des mois, voire des années après la transaction — car il résulte de processus, de personnes et de systèmes construits progressivement, souvent mal documentés au moment de la diligence raisonnable.

Continuité d'activité et gestion de crise

Un plan B documenté et testé

La gestion de la continuité d'activité (BCM) est un processus continu qui identifie les activités critiques, évalue leur vulnérabilité, et prépare les moyens de maintenir ou de rétablir rapidement le service en cas de sinistre. Elle repose sur l'engagement affiché de la direction générale, une analyse d'impact sur l'activité (BIA), et des tests réguliers du plan de continuité (BCP), notamment via des simulations de type « war room ».

RPO et RTO

Le point de reprise (RPO, « recovery point objective ») indique le volume de données que l'organisation accepte de perdre en cas d'incident, déterminé par la fréquence des sauvegardes. Le délai de reprise (RTO, « recovery time objective ») est la durée maximale d'interruption tolérable pour un processus ou un service — les régulateurs imposent des RTO maximaux aux acteurs systémiques du système financier.

Rapidité, compétence, transparence

La gestion efficace d'une crise opérationnelle repose sur trois qualités : la **rapidité** de la réponse, la **compétence** des intervenants (recours à des experts externes si nécessaire), et la **transparence** vis-à-vis des parties prenantes — car la dissimulation ou les tentatives de minimisation alimentent toujours des développements plus négatifs que la vérité assumée.

Quatre phases d'un événement opérationnel majeur

Un incident majeur traverse typiquement quatre phases : la **crise** (les premières minutes ou heures, où la nature et l'ampleur du problème se précisent), la **réponse d'urgence** (évaluation et décision sur la marche à suivre), le **rétablissement** (reprise des opérations essentielles selon le RTO prévu), et la **restauration** (retour complet à la normale, qui peut prendre des mois, voire des années pour des dommages physiques majeurs).

Le transfert du risque

L'assurance externe réduit la volatilité, sans l'éliminer

L'assurance externe réduit la volatilité du résultat en échange d'une prime régulière, mais elle n'est jamais un transfert parfait : l'organisation reste exposée à la capacité et à la volonté de l'assureur d'indemniser, et le versement peut intervenir des mois après l'incident. Une assurance a du sens pour les risques prévisibles, correctement tarifables, et facilement transférables — typiquement les événements extrêmes de type cyber ou interruption d'activité, plutôt que les petites pertes récurrentes que beaucoup de grands établissements préfèrent auto-assurer.

L'externalisation ne transfère jamais la responsabilité

L'externalisation transfère l'exécution d'une tâche à un tiers, et une partie du risque opérationnel qui lui est attaché — mais jamais la responsabilité vis-à-vis du client final. Selon la nature de l'activité externalisée et le prestataire choisi, l'externalisation peut réduire le risque global (délégation à un spécialiste plus compétent) ou l'augmenter (délocalisation motivée par la seule réduction des coûts, avec moins de contrôle et de supervision).

La gestion du risque réputationnel

Regret, raison, remède

Une communication de crise efficace suit trois principes : le **regret**, reconnaissance sincère et excuse pour l'incident; la **raison**, explication transparente des causes et des responsabilités de l'établissement; le **remède**, une solution satisfaisante d'indemnisation des parties prenantes affectées.

Étude de cas : la violation de données Capital One (2019)

Après la violation de données touchant une centaine de millions de clients, Capital One a cumulé plusieurs bonnes pratiques malgré ses défaillances de contrôle initiales : signalement rapide aux autorités, excuses publiques du PDG assumant l'entière responsabilité, communication transparente du détail des données compromises, indemnisation ciblée (surveillance du vol d'identité) et générale (renforcement des contrôles). Les contrôles préventifs existants — tokenisation des numéros de carte, absence de compromission des identifiants de connexion — ont limité l'ampleur réelle du préjudice, et une assurance de responsabilité cyber a couvert une partie des coûts de remédiation.

La réputation, un capital de résilience

Des travaux empiriques montrent que la réputation agit comme une source de résilience : elle confère aux organisations une capacité accrue à s'adapter face aux difficultés externes et à rebondir après une dégradation de performance. Une gestion exemplaire de la crise renforce à son tour la réputation — la relation fonctionne dans les deux sens.

Synthèse

Synthèse du chapitre

L'atténuation du risque opérationnel commence par le choix d'une réponse — tolérer, traiter, transférer ou terminer — puis se décline en contrôles internes (préventifs, détectifs, correctifs, directifs), dont l'efficacité doit être testée avec un niveau de rigueur croissant de l'auto-certification à la reperformance. La compréhension des trois types d'erreur humaine (glissement, erreur, violation) oriente le choix de la réponse appropriée, tandis que les méthodes d'amélioration continue (Six Sigma, DMAIC, PDSA) réduisent le risque à la source dans la conception même des processus. La continuité d'activité (RPO/RTO), la gestion de crise (rapidité, compétence, transparence), le transfert par assurance ou externalisation, et la gestion proactive de la réputation (les trois R) complètent l'arsenal — le cas Knight Capital et le cas Capital One illustrant respectivement ce qui arrive quand ces dispositifs font défaut, et comment une réponse bien conduite peut limiter les dégâts d'un incident déjà survenu.